



La información como activo de seguridad

Temas de esta sección:

- Qué significa que la información sea un activo
- Por qué la información tiene valor para una organización
- Tipos de información que puede proteger una empresa
- Diferencia entre dato, información y activo crítico
- Cómo se ve esto en un entorno SOC
- Por qué el contexto cambia la criticidad de una alerta
- Ejemplos aplicados al contexto del SOC moderno

2.1 | ¿Por qué empezamos hablando de información?



Antes de analizar alertas, procesos, malware o incidentes, necesitamos entender qué estamos intentando proteger.

En ciberseguridad no protegemos sistemas 'porque sí'. **Protegemos sistemas porque contienen, procesan, transmiten o permiten acceder a información importante.**

Esa información puede representar:

▸ Clientes, contratos, credenciales

▸ Dinero, operaciones internas

▸ Propiedad intelectual, código fuente

▸ Datos personales, decisiones estratégicas

Para un analista SOC, entender el valor de la información es clave. Una misma alerta puede tener una prioridad muy distinta según qué información esté involucrada.

2.1 | La información como activo: definición e impacto



Un activo **es algo que tiene valor para una organización**. Cuando hablamos de información como activo, nos referimos a cualquier dato o conjunto de datos que una empresa necesita proteger porque su exposición, modificación, pérdida o indisponibilidad puede generar **impacto**.

Ese impacto puede ser:

Operativo

Económico

Legal

Reputacional

Comercial

Regulatorio

La clave está en entender que no toda información tiene el mismo nivel de sensibilidad ni el mismo impacto para el negocio. Una lista de empleados, una base de clientes, un repositorio de código o una credencial administrativa no tienen el mismo valor que un documento público.

2.1 | Tipos de información en una empresa



Dentro de una empresa existen muchos tipos de información. Algunas son públicas, otras internas, otras confidenciales y otras críticas.

Datos personales de empleados o clientes	Información financiera	Contratos e información legal
Credenciales y claves API	Repositorios de código	Documentación técnica y diagramas de red
Inventario de activos	Estrategias comerciales	Reportes internos y datos de I+D

Para un analista SOC, **no alcanza con ver que 'un archivo fue accedido'**. Hay que entender qué tipo de información estaba involucrada y qué impacto podría tener si fue accedida, modificada o exfiltrada sin autorización.

2.1 | Ejemplo: descarga masiva desde SharePoint



Un SIEM genera una alerta por descarga masiva de archivos desde una plataforma cloud corporativa.

User:	jperez@empresa.com
Action:	Multiple file downloads
Source:	SharePoint
Volume:	3.8 GB
Device:	Corporate laptop
Location:	Argentina
Time:	23:48

El volumen importa, pero el tipo de información cambia completamente la prioridad:

Plantillas de marketing	Bajo riesgo
Contratos legales	Riesgo medio
Código fuente o credenciales	Riesgo crítico

Conclusión: la alerta no nos dice si fue maliciosa. Para interpretarla, necesitamos saber qué tipo de información fue descargada.

2.1 | Cómo analiza el SOC moderno una alerta de información



Ante una alerta relacionada con acceso o descarga de información, el analista no debería asumir automáticamente que hay una exfiltración. Pero tampoco cerrarla solo porque el usuario pudo autenticarse.

El análisis debería incluir preguntas como:

- | | |
|--|--|
| ? ¿Qué usuario realizó la acción y a qué área pertenece? | ? ¿Ese usuario normalmente accede a esa información? |
| ? ¿Qué tipo de archivos fueron descargados? | ? ¿El volumen y el horario tienen sentido? |
| ? ¿El dispositivo era corporativo? | ? ¿La ubicación era esperada? |
| ? ¿Se subieron archivos a un servicio externo? | ? ¿El usuario está en proceso de salida de la empresa? |

La clave no es mirar un solo dato, sino conectar información técnica con contexto de negocio.

✗ Razonamiento incompleto: "Hubo una descarga de archivos, pero el login fue exitoso, entonces es legítimo."

Un login exitoso solo indica credenciales válidas

No confirma que la actividad sea legítima. Una cuenta comprometida también puede iniciar sesión correctamente.

Un usuario interno también puede hacer uso indebido

El hecho de que el usuario tenga acceso autorizado no significa que la acción sea correcta.

Una sesión con MFA también puede ser abusada

El usuario pudo haber aprobado por error, o el atacante ya tenía acceso al dispositivo (MFA fatigue).

La pregunta correcta no es "¿el acceso fue exitoso?" sino "**¿ese acceso y esa acción tienen sentido para ese usuario, ese activo y ese contexto?**"

2.1 | Mini escenario: dos contextos, mismo evento



Misma alerta base — distinto contexto — distinta prioridad

CASO 1 — Contexto bajo riesgo

Datos del evento:

rrhh.gomez@empresa.com | Bulk download 1.2GB |
Evaluaciones_Desempeño_2025
10:35 AM | Corporate laptop | Buenos Aires | MFA: Success

Análisis inicial:

La actividad puede ser legítima: horario laboral, dispositivo corporativo, ubicación esperada, usuario de RRHH accediendo a datos de RRHH.
Decisión: validar si era esperado, pero la probabilidad de legitimidad es alta.

CASO 2 — Contexto alto riesgo

Datos del evento:

rrhh.gomez@empresa.com | Bulk download 1.2GB |
Evaluaciones_Desempeño_2025
02:14 AM | Unknown device | Foreign IP | MFA: Success | Upload to
personal cloud

Análisis inicial:

El evento base es igual, pero el contexto cambia todo: horario inusual, dispositivo desconocido, IP extranjera, subida posterior a almacenamiento personal.
MFA exitoso no alcanza para descartar compromiso o uso indebido.



ACCIONES ESPERADAS	ERRORES A EVITAR
✓ Revisar usuario, activo y acción realizada	✗ Cerrar solo porque el acceso fue autorizado
✓ Validar si el usuario tiene relación con esa información	✗ Asumir que todo acceso fuera de horario es malicioso
✓ Revisar historial y actividad previa/posterior	✗ Confirmar exfiltración sin evidencia
✓ Verificar dispositivo, ubicación y MFA	✗ Escalar sin incluir contexto suficiente
✓ Documentar evidencia y limitaciones	✗ Descargar o abrir archivos sensibles innecesariamente
✓ Escalar si el riesgo lo justifica	✗ Compartir información fuera de canales autorizados